



Ready Education, LLC

INCIDENT RESPONSE PLAN

Version Number:	1.0
Version Date:	5/25/2024
Created by:	Michael Johnson
Approved by:	Steve Pawlish
Confidentiality level:	Restricted

Change history

Date	Version	Responsible Party	Description of change
3/1/2024	1.0	Michael Johnson	Basic document outline
3/1/2024	1.0	Michael Johnson	Draft Submitted for review
5/25/2024	1.0	Steve Pawlish	Draft document approved

Table of contents

1 PURPOSE	4
2 SCOPE	4
3 INCIDENT AND EVENT DEFINITIONS	4
4 INCIDENT REPORTING & DOCUMENTATION	4
4.1 Reporting	4
4.2 Severity	4
4.2.1 S3/S4 - Low and Medium Severity	4
4.2.2 S2 - High Severity	4
4.2.3 S1 - Critical Severity	5
4.3 Escalation and Internal Reporting	5
4.4 Documentation	5
5 INCIDENT RESPONSE PROCESS	5
5.1 Summary	5
5.2 Detailed	5
5.3 Incident Response Meeting Agenda	6
5.4 Special Consideration	6
5.4.1 Internal Issues	6
5.4.2 Compromised Communications	6
5.4.3 Root Account Compromise	6
5.4.4 Additional Requirements	6
6 EXTERNAL COMMUNICATIONS AND BREACH REPORTING	7
7 MITIGATION AND REMEDIATION	7
8 COOPERATION WITH CUSTOMERS, DATA CONTROLLER AND AUTHORITIES	7
9 ROLES & RESPONSIBILITIES	7
9.1 Response Team Members	7
9.2 Management Commitment	8
10 EXCEPTIONS	8
11 NON-COMPLIANCE	9
12 VALIDITY AND DOCUMENT MANAGEMENT	9
APPENDIX A – AWS ROOT ACCOUNT COMPROMISE PLAYBOOK	10
Incident Response Runbook - Root Usage	10
Objective	10
Assumptions	10
Indicators of Compromise	10
Steps to Remediate - Establish Control	10
Further Action Items - Determine Impact	11

1 Purpose

This document establishes the plan for managing information security incidents and events, and offers guidance for employees or incident responders who believe they have discovered, or are responding to, a security incident.

2 Scope

This policy covers all information security or data privacy events or incidents.

3 Incident and Event Definitions

A security event is an observable occurrence relevant to the confidentiality, availability, integrity, or privacy of company-controlled data, systems or networks.

A security incident is a security event which results in loss or damage to the confidentiality, availability, integrity, or privacy of company-controlled data, systems or networks.

4 Incident Reporting & Documentation

4.1 Reporting

If a Ready Education, LLC employee, contractor, user, or customer becomes aware of an information security event or incident, possible incident, imminent incident, unauthorized access, policy violation, security weakness, or suspicious activity, then they shall immediately report the information using one of the following communication channels:

- Email security@readyeducation.com information or reports about the event or incident

Reporters should act as a good witness and behave as if they are reporting a crime. Reports should include specific details about what has been observed or discovered.

4.2 Severity

Ready Education, LLC Support NOC shall monitor incident and event tickets and shall assign a ticket severity based on the following categories.

4.2.1 S3/S4 - Low and Medium Severity

Issues meeting this severity are simply suspicions or odd behaviors. They are not verified and require further investigation. There is no clear indicator that systems have tangible risk and do not require emergency response. This includes lost/stolen laptop with disk encryption, suspicious emails, outages, strange activity on a laptop, etc.

4.2.2 S2 - High Severity

High severity issues relate to problems where an adversary or active exploitation hasn't been proven yet, and may not have happened, but is likely to happen. This may include lost/stolen laptop without encryption, vulnerabilities with direct risk of exploitation, threats with risk or adversarial persistence on our systems (e.g.: backdoors, malware), malicious access of business data (e.g.: passwords, vulnerability data, payments information).

4.2.3 S1 - Critical Severity

Critical issues relate to actively exploited risks and involve a malicious actor or threats that put any individual at risk of physical harm. Identification of active exploitation is required to meet this severity category.

4.3 Escalation and Internal Reporting

The incident escalation contacts can be found below on the internal emergency contact board.

S1 - Critical Severity: S1 issues require immediate notification to Security management.

S2 - High Severity: A support ticket must be created, and the appropriate manager (see S1 above) must also be notified via email with a reference to the ticket number.

S3/S4 - Medium and Low Severity: A support ticket must be created and assigned to the appropriate department for response.

4.4 Documentation

All reported security events, incidents, and response activities shall be documented and adequately protected in the Jira Security ticket system.

A root cause analysis may be performed on all verified S1 security incidents. A root cause analysis report shall be documented and referenced in the incident ticket. The root cause analysis shall be reviewed by the CTO who shall determine if a post-mortem meeting will be called.

5 Incident Response Process

For critical issues, the response team will follow an iterative response process designed to investigate, contain exploitation, eradicate the threat, recover system and services, remediate vulnerabilities, and document a post-mortem report including the lessons learned from the incident.

5.1 Summary

- Event reported
- Triage and analysis
- Investigation
- Containment & neutralization (short term/triage)
- Recovery & vulnerability remediation
- Hardening & Detection improvements (lessons learned, long term response)

5.2 Detailed

- The CTO or a designee will manage the incident response effort
- If necessary, a central "War Room" will be designated, which may be a physical or virtual location (i.e Teams channel)
- A recurring Incident Response Meeting will occur at regular intervals until the incident is resolved
- Legal and executive staff will be informed as required

5.3 Incident Response Meeting Agenda

- Update Incident Ticket and timelines
- Document new Indicators of Compromise (IOCs)
- Perform investigative Q&A
- Apply emergency mitigations
- External Reporting / Breach Reporting
- Plan long term mitigations
- Document Root Cause Analysis (RCA)
- Additional items as needed

5.4 Special Consideration

5.4.1 Internal Issues

Issues where the malicious actor is an internal employee, contractor, vendor, or partner requires sensitive handling. The incident manager shall contact HR directly and will not discuss with other employees. These are critical issues where follow-up must occur.

5.4.2 Compromised Communications

Incident responders must have Teams messaging arranged before listing themselves as incident members. If there are IT communication risks, an out of band solution will be chosen, and communicated to incident responders via cell phone.

5.4.3 Root Account Compromise

If an AWS root account compromise is known or expected, refer to the playbook in Appendix A.

5.4.4 Additional Requirements

- Suspected and reported events and incidents shall be documented
- Suspected incidents shall be assessed and classified as either an event or an incident
- Incident response shall be performed according to this plan and any associated procedures.
- All incidents shall be formally documented, and a documented root cause analysis shall be performed
- Incident responders shall collect, store, and preserve incident-related evidence in accordance with industry guidance and best practices such as NIST SP 800-86 'Guide to Integrating Forensic Techniques into Incident Response'
- Suspected and confirmed unauthorized access events shall be reviewed by the Incident Response Team. Breach determinations shall only be made by the CEO and legal counsel in coordination with executive management
- Ready Education, LLC shall promptly and properly notify customers, partners, users, affected parties, and regulatory agencies of relevant incidents or breaches in accordance with Ready Education, LLC policies, contractual commitments, and regulatory requirements, as determined by the Legal Department
- This Incident Response Plan shall be reviewed and formally tested at least annually. Results of IR plan testing activities including findings and lessons learned will be formally documented and maintained to support security, compliance and audit requirements

6 External Communications and Breach Reporting

Legal and executive staff shall confer with technical teams in the event of unauthorized access to company or customer systems, networks, and/or data. Legal staff along with the CEO shall determine if breach reporting or external communications are required. Breaches shall be reported to customers, consumers, data subjects and regulators without undue delay and in accordance with all contractual commitments and applicable legislation.

No personnel may disclose information regarding incident or potential breaches to any third party or unauthorized person without the approval of legal and/or executive management.

7 Mitigation and Remediation

Legal and executive staff shall determine any immediate or long-term mitigations or remedial actions that need to be taken as a result of an incident or breach. In the event that mitigations or remedial actions are needed, executive staff shall direct personnel with respect to planning, communicating and executing those activities.

8 Cooperation with Customers, Data Controller and Authorities

As needed and determined by legal and executive staff, the company shall cooperate with customers, Data Controllers and regulators to fulfill all of its obligations in the event of an incident or data breach.

9 Roles & Responsibilities

Every employee and user of any Ready Education, LLC information resources has responsibilities toward the protection of the information assets. The table below establishes the specific responsibilities of the incident responder roles.

9.1 Response Team Members

Role	Responsibility
Incident Manager	The Incident Manager is the primary and ultimate decision maker during the response period. The Incident Manager is ultimately responsible for resolving the incident and formally closing incident response actions. See the internal contact list for Incident Manager contact information. These responsibilities include: • Ensuring the right people from all functions are actively involved as appropriate • Communicating status updates to the appropriate person or teams at regular intervals • Resolving incidents in the immediate term • Determining necessary follow-up actions • Assigning follow-up activities to the appropriate people • Promptly reporting incident details which may trigger breach reporting, in writing to Executive Leadership

Incident Response Team (IRT)	The individuals who have been engaged and are actively working on the incident. All members of the IRT will remain engaged in incident response until the incident is formally resolved, or they are formally dismissed by the Incident Manager. The slack channel for this team is a private channel #infosec and people can create Jira tickets at helpme.readyeducation.com using a Security Incident type.
Engineers (Support and Development)	Qualified engineers will be placed into the on-call rotation and may act as the Incident Manager (if primary resources are not available) or a member of the IRT when engaged to respond to an incident. Engineers are responsible for understanding the technologies and components of the information systems, the security controls in place including logging, monitoring, and alerting tools, appropriate communications channels, incident response protocols, escalation procedures, and documentation requirements. When Engineers are engaged in incident response, they become members of the IRT.
Users	Employees and contractors of Ready Education, LLC. Users are responsible for following policies, reporting problems, suspected problems, weaknesses, suspicious activity, and security incidents and events.
Customers	Customers are responsible for reporting problems with their use of Ready Education, LLC services. Customers are responsible for verifying that reported problems are resolved.
Legal Counsel	Responsible, in conjunction with the CEO and executive management, for determining if an incident presents legal or regulatory exposure as well as whether an incident shall be considered a reportable breach. Counsel shall review and approve in writing all external breach notices before they are sent to any external party.
Executive Management	Responsible, in conjunction with the CEO and Legal Counsel, for determining if an incident shall be considered a reportable breach. An appropriate company officer shall review and approve in writing all external breach notices before they are sent to any external party. Ready Education, LLC shall seek stakeholder consensus when determining whether a breach has occurred. The Ready Education, LLC CEO shall make a final breach determination in the event that consensus cannot be reached.

9.2 Management Commitment

Ready Education, LLC management has approved this policy and commits to providing the resources, tools and training needed to reasonably respond to identified security events and incidents with the potential to adversely affect the company or its customers.

10 Exceptions

Requests for an exception to this Policy must be submitted to and authorized by the VP of Information Security for approval. Exceptions shall be documented.

11 Non-Compliance

Violations of the policy may subject employees to disciplinary action, including removal of privilege to systems, up to and including termination of employment. Sanctions for non-compliance may include, but are not limited to, one or more of the following:

Disciplinary action according to applicable Ready Education, LLC policies.

Termination of employment.

Legal action according to applicable laws and contractual agreements.

12 Validity and document management

This document is valid as of 5/25/2024.

The owner of this document is the IT Manager, who must check and, if necessary, update the document at least once every 12 months.

Appendix A – AWS Root Account Compromise Playbook

Incident Response Runbook - Root Usage

Objective

The objective of this runbook is to provide specific guidance on how to manage Root AWS account usage. This runbook is not a substitute for an in-depth Incident Response strategy. This runbook focuses on the IR lifecycle:

- Establish control.
- Determine impact.
- Recover as needed.
- Investigate the root cause.
- Improve.

The Indicators of Compromise (IOC), initial steps (stop the bleeding), and the detailed CLI commands needed to execute those steps are listed below.

Assumptions

- CLI configured and installed.
- Reporting process is already in place.
- Trusted Advisor is active.
- Security Hub is active.

Indicators of Compromise

- Activity that is abnormal for the account.
 - Creation of IAM users.
 - CloudTrail turned off.
 - Cloudwatch turned off.
 - SNS paused.
 - Step Functions paused.
- Launching of new or unexpected AMIs.
- Changes to the contacts on the account.

Steps to Remediate - Establish Control

AWS documentation for a possible compromised account calls out the specific tasks listed below. The documentation for a possible compromised account can be found at: [What do I do if I notice unauthorized activity in my AWS account?](#)

1. Contact AWS Support and TAM as soon as possible.
2. Change and rotate Root password and add an MFA device associated with Root.
3. Rotate passwords, access/secret keys, and CLI commands relevant to remediation steps.
4. Review actions taken by the root user.
5. Open the runbooks for those actions.
6. Close incident.
7. Review the incident and understand what happened.
8. Fix the underlying issues, implement improvements, and update the runbook as needed.

Further Action Items - Determine Impact

Review created items and mutating calls. There may be items that have been created to allow access in the future. Some things to look at:

- IAM Cross account roles.
- IAM Users.
- S3 buckets.
- EC2 instances.
- ECS instances.
- RDS Databases.

EMPLOYEE ACKNOWLEDGEMENT

Employee Name: Sujana Nagaraj

Date: 07/18/2025

Employee Signature: *sujana nagaraj*


